



Certified Penetration Testing Professional

WPScan Cheat Sheet

WPScan

Source: <https://github.com>

WPScan is a powerful tool used by attackers to identify vulnerabilities in WordPress websites. It automates the process of discovering security issues, outdated components, and potential entry points that can be exploited.

Syntax
<code>wpscan --url <URL> --enumerate p</code>

Options	
<code>--url URL</code>	The URL of the blog to scan. Allowed Protocols: http, https. Default Protocol if none provided: http. This option is mandatory unless update or help or hh or version is/are supplied.
<code>-h, --help</code>	Display the simple help and exit.
<code>--hh</code>	Display the full help and exit.
<code>--version</code>	Display the version and exit.
<code>-v, --verbose</code>	Verbose mode.
<code>--[no-]banner</code>	Whether or not to display the banner. Default: true.
<code>-o, --output FILE</code>	Output to FILE.
<code>-f, --format FORMAT</code>	Output results in the format supplied. Available choices: cli-no-color, json, cli, cli-no-colour.
<code>--detection-mode MODE</code>	Default: mixed. Available choices: mixed, passive, aggressive.
<code>--user-agent, --ua VALUE</code>	Specify a custom user-agent.

--random-user-agent, --rua	Use a random user-agent for each scan.
--http-auth login:password	HTTP authentication credentials.
-t, --max-threads VALUE	The max threads to use. Default: 5.
--throttle MilliSeconds	Milliseconds to wait before doing another web request. If used, the max threads will be set to 1.
--request-timeout SECONDS	The request timeout in seconds. Default: 60.
--connect-timeout SECONDS	The connection timeout in seconds. Default: 30.
--disable-tls-checks	Disables SSL/TLS certificate verification, and downgrade to TLS1.0+ (requires cURL 7.66 for the latter).
--proxy protocol://IP:port	Supported protocols depend on the cURL installed.
--proxy-auth login:password	Proxy authentication credentials.
--cookie-string COOKIE	Cookie string to use in requests, format: cookie1=value1[; cookie2=value2].
--cookie-jar FILE-PATH	File to read and write cookies. Default: /tmp/wpscan/cookie_jar.txt.
--force	Do not check if the target is running WordPress or returns a 403.
--[no-]update	Whether or not to update the Database.
--api-token TOKEN	The WPScan API Token to display vulnerability data, available at https://wpscan.com/profile .
--wp-content-dir DIR	The wp-content directory if custom or not detected, such as "wp-content".
--wp-plugins-dir DIR	The plugins directory if custom or not detected, such as "wp-content/plugins".
-e, --enumerate [OPTS]	Enumeration Process. Available Choices: vp Vulnerable plugins, ap All plugins, p Popular plugins, vt Vulnerable themes, at All themes, t Popular themes, tt Timthumbs, cb Config backups, dbe Db exports, u User IDs range (e.g. u1-5), m Media IDs range (e.g. m1-15). Separator to use between the values: ','. Default: All Plugins, Config Backups. Value if no argument supplied: vp, vt, tt, cb, dbe, u, m. Incompatible choices (only one of each group/s can be used): - vp, ap, p - vt, at, t
--exclude-content-based REGEXP_OR_STRING	Exclude all responses matching the Regexp (case insensitive) during parts of the enumeration. Both the headers and body are checked. Regexp delimiters are not required.

--plugins-detection MODE	Use the supplied mode to enumerate Plugins. Default: passive. Available choices: mixed, passive, aggressive.
--plugins-version-detection MODE	Use the supplied mode to check plugins' versions. Default: mixed. Available choices: mixed, passive, aggressive.
--exclude-usernames REGEXP_OR_STRING	Exclude usernames matching the Regexp/string (case insensitive). Regexp delimiters are not required.
-P, --passwords FILE-PATH	List of passwords to use during the password attack. If no --username/s option supplied, user enumeration will be run.
-U, --usernames LIST	List of usernames to use during the password attack. Examples: 'a1', 'a1,a2,a3', '/tmp/a.txt'.
--multicall-max-passwords MAX_PWD	Maximum number of passwords to send by request with XMLRPC multicall. Default: 500.
--password-attack ATTACK	Force the supplied attack to be used rather than automatically determining one. Multicall will only work against WP < 4.4. Available choices: wp-login, xmlrpc, xmlrpc-multicall.
--login-uri URI	The URI of the login page if different from /wp-login.php.
--stealthy	Alias for --random-user-agent --detection-mode passive --plugins-version-detection passive.

Example Commands

Command	Description
wpscan --url http://example.com	Performs a basic scan of the specified WordPress site.
wpscan --url http://example.com - -enumerate p	Enumerates all installed plugins on the specified site and checks for known vulnerabilities.
wpscan --url http://example.com - -enumerate t	Enumerates all installed themes on the specified site and checks for known vulnerabilities.
wpscan --url http://example.com - -enumerate u	Enumerates all users on the specified site.
wpscan --url http://example.com - -passwords /path/to/passwords.txt	Performs a brute-force attack using the specified password list.
wpscan --url http://example.com - -api-token YOUR_API_TOKEN	Uses the WPScan API to get the latest vulnerability data.
wpscan --url http://example.com - -random-user-agent	Uses a random user-agent for the scan to avoid detection.

<code>wpscan --update</code>	Updates WPScan to the latest version.
<code>wpscan --url http://example.com - -proxy http://127.0.0.1:8080</code>	Uses a proxy server for the scan.
<code>wpscan --url http://example.com - -user-agent "CustomUserAgent"</code>	Uses a custom user-agent for the scan.
<code>wpscan --url http://example.com - -max-threads 10</code>	Uses 10 threads for the scan.
<code>wpscan --url http://example.com - -output results.json --format json</code>	Outputs the scan results to a file in JSON format.
<code>wpscan --url http://example.com - -detection-mode aggressive</code>	Uses aggressive detection mode for the scan.
<code>wpscan --url http://example.com - -enumerate ap</code>	Enumerates all plugins, not just the vulnerable ones.
<code>wpscan --url http://example.com - -enumerate at</code>	Enumerates all themes, not just the vulnerable ones.
<code>wpscan --url http://example.com - -request-timeout 120</code>	Sets the request timeout to 120 seconds.
<code>wpscan --url http://example.com - -connect-timeout 60</code>	Sets the connection timeout to 60 seconds.
<code>wpscan --url http://example.com - -disable-tls-checks</code>	Disables SSL/TLS certificate verification.
<code>wpscan --url http://example.com - -cookie-string "cookie1=value1; cookie2=value2"</code>	Uses a specified cookie string in requests.
<code>wpscan --url http://example.com - -exclude-usernames admin,editor</code>	Excludes specific usernames from the enumeration.
<code>wpscan --url http://example.com - -multicall-max-passwords 1000</code>	Sets the maximum number of passwords to send by request with XMLRPC multicall to 1000.
<code>wpscan --url http://example.com - -password-attack wp-login</code>	Forces the use of wp-login for the password attack.
<code>wpscan --url http://example.com - -login-uri /custom-login.php</code>	Specifies a custom login URI for the scan.
<code>wpscan --url http://example.com - -stealthy</code>	Uses stealthy mode (random user-agent, passive detection, passive plugin version detection).